Vendor ThirdParty Risk Management

Capulus Technologies - Vendor and Third■Party Risk Management Policy
Version 1.2 - Effective January 1, 2024

1.0 Introduction
This policy ensures that all vendors, suppliers, and partners who interact with Capulus data or systems meet our security, privacy, and ethical standards.

2.0 Risk Categorization
Vendors are categorized based on the sensitivity of data they access:
• Tier 1 (Low Risk): No access to internal systems or data (e.g., office supplies).
• Tier 2 (Moderate Risk): Access to internal non■confidential data (e.g., HR platforms).
• Tier 3 (High Risk): Access to confidential or restricted data (e.g., cloud infrastructure, AI model training data).

3.0 Due Diligence Requirements
3.1 Tier 1 Vendors
• Basic vendor information (W■9, business license).

3.2 Tier 2 Vendors
• Tier 1 requirements plus:
• Security questionnaire.
• Review of vendor's privacy policy.
• Business continuity/disaster recovery summary.

3.3 Tier 3 Vendors
• Tier 2 requirements plus:
• On■site audit (or third■party audit report e.g., SOC2).
• Penetration testing results.
• Contractual clauses for data protection, breach notification, and right to audit.
• Proof of compliance with relevant regulations (GDPR, local policing data laws).

4.0 Ongoing Monitoring
• Annual review for all Tier 3 vendors.
• Quarterly security scorecard for critical vendors.
• Immediate re-assessment after any security incident involving the vendor.

5.0 Vendor Offboarding
• Access revocation within 24 hours of contract termination.
• Certification of data destruction or return.
• Final security review.

6.0 Responsibilities
• Procurement: Initiates due diligence.
• IT Security: Performs technical assessments.
• Legal: Reviews contracts and data protection clauses.

Non■compliance: Failure to adhere to this policy may result in termination of the vendor relationship.